

🎓 Autorización y Categorías de Control de Seguridad

1 Introducción: ¿Qué es la autorización?

🔑 **Definición sencilla:** La autorización es el proceso que determina **qué puede hacer un usuario** una vez que ya ha sido autenticado. Es decir, **ya sabemos quién es**, ahora decidimos **qué puede acceder, modificar o utilizar**.

🎬 **Ejemplo realista:** En una empresa, Juan entra con su credencial (autenticación). Luego, el sistema revisa y le da acceso solo al área de recursos humanos, no a la base de datos de ingeniería (autorización).

👤 por Alvaro Chirou

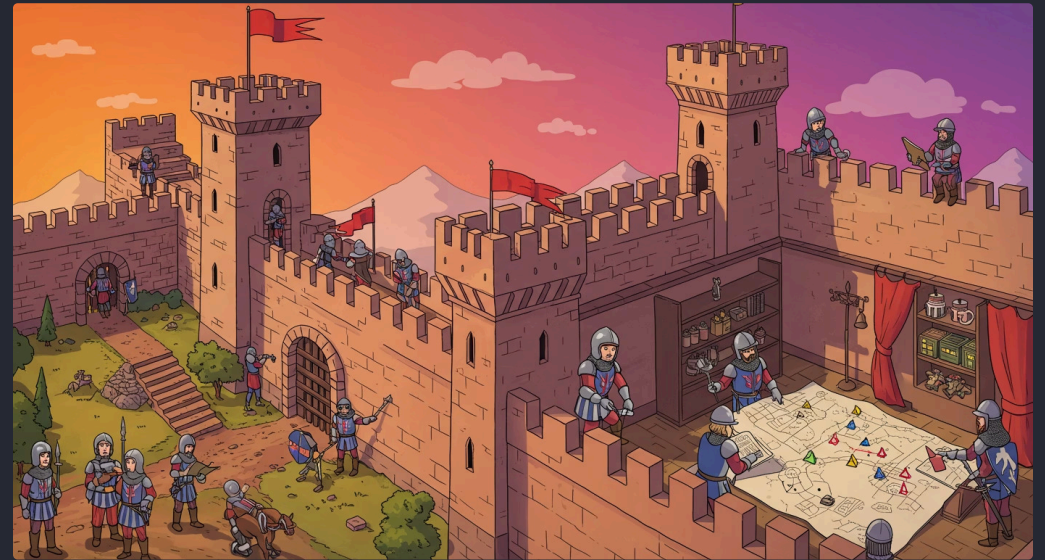


Capas de defensa: Metáfora del castillo

Imaginemos que protegemos un **castillo medieval**, que representa nuestra red o sistema informático:

- 🧱 **Muros:** Controles técnicos
- 👁️ **Torres de vigilancia:** Controles físicos
- 📋 **Guardias con manuales:** Controles operativos
- 🧠 **Estrategia del comandante:** Controles de gestión

Este enfoque se conoce como **defensa en profundidad**: no confiamos en una sola barrera, sino en muchas capas.



Las 4 Categorías de Control de Seguridad

A. Controles Técnicos (Lógicos)

 Son herramientas tecnológicas que actúan automáticamente.

Ejemplos:

- Firewalls que bloquean accesos no autorizados.
- Sistemas de cifrado que protegen archivos sensibles.
- Antivirus que detectan software malicioso.

 "Es como tener una cerradura electrónica que solo abre con huella digital."

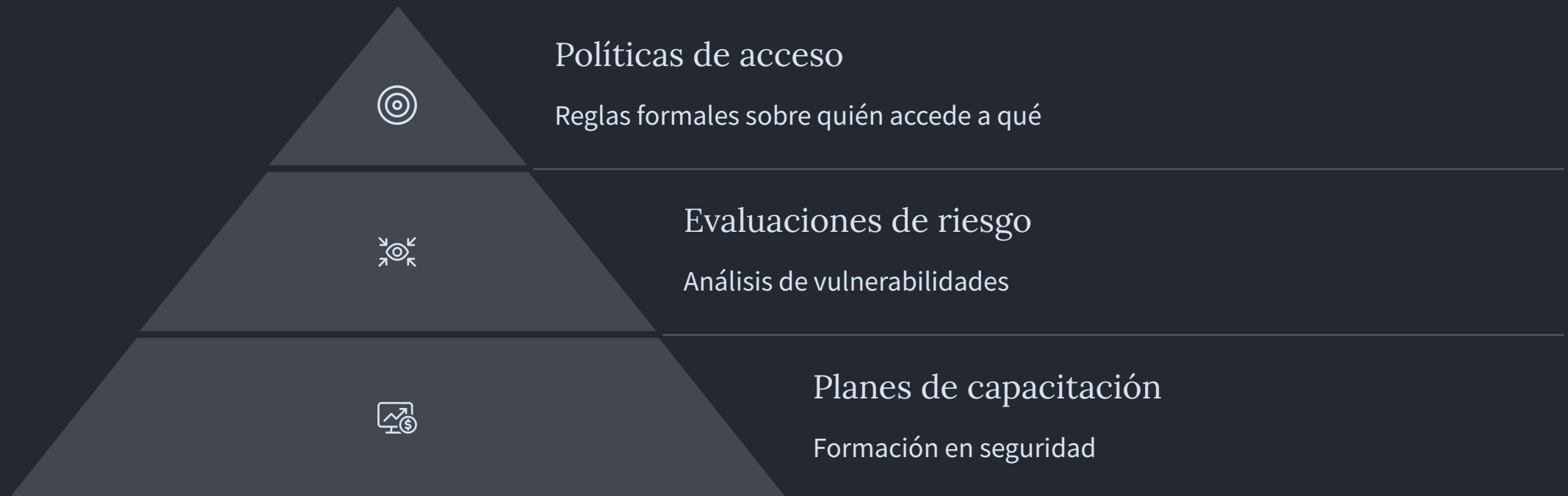


Controles de Gestión (Administrativos)

B. Controles de Gestión (Administrativos)

 Reglas y decisiones estratégicas sobre la seguridad.

Ejemplos:



 "Es como decidir quién puede tener llaves y cuándo deben devolverlas."

Controles Operativos

C. Controles Operativos

 Son procedimientos del día a día que las personas deben seguir.

Ejemplos:

Cambiar contraseñas cada 90 días

Actualización periódica de credenciales



AD

Revisión de accesos

Verificación regular de permisos

Procedimientos de respaldo

Copias de seguridad programadas



 "Es como revisar cada noche si las puertas están cerradas correctamente."

Controles Físicos

D. Controles Físicos

 Protegen los sistemas a nivel físico.

Ejemplos:



Cámaras de vigilancia

Monitoreo visual constante



Cerraduras, vallas o sensores

Barreras físicas de acceso



Guardia de seguridad

Personal de vigilancia

 "Es como tener un guardia en la puerta del castillo que controla quién entra."

Autorización y su relación con los controles

 La autorización **no es solo una decisión digital**, se apoya en todas estas capas:

- **Técnico:** reglas en firewalls o en sistemas RBAC.
- **Gestión:** políticas de acceso por rol o confidencialidad.
- **Operativo:** procesos que asignan y revocan permisos.
- **Físico:** acceso físico a un servidor depende de la autorización.

 **Ejemplo integrador:** En una empresa, para que Marta acceda a datos confidenciales:

- Su rol debe tener permiso (gestión),
- El sistema debe aplicar esos permisos (técnico),
- El personal de TI debe haberla registrado en el sistema (operativo),
- Y tal vez el servidor está en una sala con acceso restringido (físico).